

AS501 CKYC INITIAL SUBMISSION API

Complete Test Strategy & Execution Plan

Screenzaa by TrackWizz | CERSAI CKYC Registry

API Reference: AS501 V1.2 | Context-Driven Testing Approach

Document Version: 1.0 | Date: 07 May 2026

13 PHASES	1,415+ TEST CASES	31 WEEKS	98% CONFIDENCE
-----------	-------------------	----------	----------------

Prepared by: CKYC Test Engineering Team	Domain: BFSI / CKYC / CERSAI	Testing Approach: Context Driven
---	------------------------------	----------------------------------

Executive Summary

This document defines the complete test strategy for the **AS501 CKYC Initial Submission API** developed by Screenzaa by TrackWizz. The API enables Financial Institutions (FIs) and Reporting Entities (REs) across India to submit customer KYC data to the **CERSAI Central KYC Registry**. Given that this API serves as national financial infrastructure — touching 800+ million Indian banking customers across 12,000+ financial institutions — the testing strategy has been designed with the highest standards of thoroughness, regulatory compliance, and production resilience.

Attribute	Details
API Name	AS501 — CKYC Initial Submission
API Version	V1.2 (07-Jan-2026)
Purpose Code	09 — CKYC Initial Submission
Encryption	AES-256 + RSA (1024/2048-bit) + Digital Signature
Testing Approach	Context-Driven Black Box White Box Exploratory
Total Phases	13 Phases (Phase 0 through Phase 13)
Total Test Cases	1,415+ (Phase 0-8) growing to 3,000+ by Year 1
Total Duration	31 Weeks (parallel streams: 20 weeks effective)
Target Confidence	98% after all 13 phases + canary release
Regulatory Framework	RBI KYC Master Directions PMLA 2002 DPDP Act 2023 FATCA/CRS

Why This API Demands Exceptional Testing

The AS501 API is not merely a software component — it is a **regulatory submission channel** connecting India's banking ecosystem to CERSAI. A single undetected bug can result in:

- Regulatory rejection of customer CKYC records at CERSAI
- PMLA compliance failure for the Financial Institution
- Financial penalties from RBI/SEBI/IRDAI
- Customer onboarding delays impacting account operations
- Audit failures during RBI inspections
- Reputational damage to both TrackWizz and the FI

■ **CRITICAL:** Zero tolerance for false acceptances (invalid data accepted) and false rejections (valid data rejected). Both are equally damaging in the CKYC context.

Table of Contents

1. Executive Summary	2
2. API Architecture Overview	4
3. Testing Approach & Philosophy	5
4. Confidence Assessment	6
5. Phase 0 — Foundation & Environment Setup	7
6. Phase 1 — Field Level Validation (Atomic)	8
7. Phase 2 — Object Level Validation (Structural)	11
8. Phase 3 — Business Rule & CKYC Domain Validation	12
9. Phase 4 — API Contract & Protocol Testing	15
10. Phase 5 — Integration & End-to-End Testing	16
11. Phase 6 — Security & Encryption Testing	17
12. Phase 7 — Performance & Load Testing	18
13. Phase 8 — Production Simulation & Chaos Testing	19
14. Phase 9 — CERSAI Integration Validation	20
15. Phase 10 — Pilot Bank UAT	21
16. Phase 11 — Independent Security Audit	22
17. Phase 12 — Observability & Runbook Validation	22
18. Phase 13 — Canary / Shadow Production Release	23
19. Complete Test Case Count Summary	24
20. Production Readiness Golden Rules	25
21. Post-Production Considerations	26

API Architecture Overview

The AS501 API is a RESTful service that handles **three distinct customer types** within a single JSON request structure. Understanding this architecture is fundamental to designing comprehensive tests.

Component	Description	Key Testing Focus
HTTP Headers	ApiToken, Cluster (CL1_User), Domain (I)	Auth, static values, tenant isolation
Main Request	requestId, sourceSystemName, purpose=09	Uniqueness, source registration, purpose code
customerList	Individual (type 1,5,7,27) or Legal Entity (type 2,8..101+)	ConstitutionType rules, all field validations
documentList	Embedded in customer — Base64 encoded documents	Document type vs customer type, Base64 integrity
taxDetailDtoList	Embedded in Legal Entity — FATCA/CRS tax info	Multi-country tax residency, TIN formats
relatedPersonList	Embedded in LE — Directors, Partners, UBOs etc.	RP-specific mandatory fields, relation codes
customerRelationDtoList	Root level — links customers to related persons	Linkage integrity, requestId match, date rules
Encryption Layer	AES-256 (data) + RSA (session key) + Digital Signature	Key sizes, signature verification, replay attacks

Two Levels of Failure Response

Failure Level	When It Occurs	Response Behaviour
Request Level	Unregistered sourceSystemName, invalid headers, malformed JSON	response: null validationCode + validationDescription populated
Record Level	Field validation failures, business rule violations, document errors	overallStatus: RejectedByTW purposeResponse with failure details

Testing Approach & Philosophy

Testing Techniques Applied

Black Box Techniques

- Equivalence Partitioning — valid/invalid enum values, date formats, field lengths
- Boundary Value Analysis — MAX length fields, date extremes, numeric limits
- Decision Table Testing — formSixty vs PAN, constitutionType field applicability matrix
- State Transition Testing — Customer status lifecycle, demise flow transitions
- Use Case / Scenario Testing — End-to-end CKYC submission journeys

White Box Techniques

- Condition Coverage — Subjective field trigger logic (fatherPrefix when fatherFirstName given)
- Path Coverage — Request routing: valid source → processing vs unknown → rejection
- Data Flow Analysis — requestId uniqueness propagation through response chain

Exploratory Testing

- Session-based exploration of enum combinations (constitutionType vs document type mismatches)
- Exploring partial data submission response behaviour
- Probing encryption edge cases with mismatched key pairs
- CKYC regulatory risk scenarios (minor + Video KYC, NRI + Indian documents)

Core Testing Philosophy

Inside-Out Testing Strategy: Start from the smallest unit (single field) → Build to full request object → Build to multi-record request → Build to production simulation. Each phase builds on the verified foundation of the previous phase.

Principle	Application
CKYC Domain Rules Override API Rules	When in doubt, CERSAI specifications take precedence over API documentation.
Real Data Beats Synthetic Data	Always include regional name patterns, legacy CBS data formats, and linguistic variations.
Zero Tolerance Policy	No false acceptances (invalid data accepted) AND no false rejections (valid data rejected).
Fail Safe, Not Fail Silent	Every failure must return a meaningful, actionable error message with a validation code.
Test the Encrypted Path	Both decrypted (logic) and encrypted (integration) paths must be tested independently.

Confidence Assessment & Production Readiness

Confidence Score After Each Stage

Stage	Phases Completed	Confidence	Gap / Risk
Core Testing	Phase 0 — 8	78-82%	Real data diversity, CERSAI grey areas, legacy CBS unknown
+ CERSAI Integration	+ Phase 9	83%	Real bank data not yet tested
+ Pilot Bank UAT	+ Phase 10	91%	Security not independently certified
+ Security Audit	+ Phase 11	95%	Production monitoring not validated
+ Observability	+ Phase 12	96%	Real production traffic not observed
+ Canary Release	+ Phase 13	98%	Remaining 2% = Unknown unknowns (always exist)

■ **CRITICAL:** 100% confidence is a myth for any API serving 800 million customers. 98% with proper monitoring, fast incident response, and rollback capability is the industry gold standard for national-scale financial infrastructure.

PHASE 0

Foundation & Environment Setup

Objective: Ensure the entire test infrastructure is validated and operational before a single functional test case is executed. A flawed environment produces misleading results. **Duration:** 1 Week | **Test Cases:** ~20 | **Priority:** BLOCKER

0.1 Test Environment Setup

- TrackWizz Sandbox/UAT environment accessible and stable
- CERSAI Sandbox connectivity confirmed (ping + basic auth)
- ApiToken procured for test environment — valid and active
- Minimum 3 Source Systems registered: System-A (valid tests), System-B (concurrent tests), System-C (negative tests)
- Domain/Tenant URL confirmed for test environment
- HTTP status 200 received on health-check endpoint

0.2 Test Data Preparation

- Valid Individual master record template (all fields populated correctly)
- Valid Legal Entity master record template
- Valid Related Party master record template
- Document Base64 samples: Photograph (small/medium/large), AadhaarCard, Passport, VoterID, CIN, Death Certificate
- Invalid Base64 samples for negative document tests
- Boundary value data sets for all field length tests
- All enum value catalogues cross-referenced with API documentation

0.3 Encryption Infrastructure Setup

- RSA Key Pair generated — 1024-bit (test set A)
- RSA Key Pair generated — 2048-bit (test set B)
- Receiver's Public Key procured from TrackWizz team
- Sender's Private Key configured for digital signature tests
- Encryption utility library installed and round-trip tested
- AES-256 session key generation script validated

0.4 Tooling Configuration

- API testing tool configured (Postman/REST Assured collection structure created)
- Environment variables set: apiToken, cluster, domain, sourceSystemName, baseUrl
- JSON schema validator configured against documented response schemas
- Response assertion library configured for automated validations
- Test data generator scripts for bulk data creation
- Defect tracking system integrated with test execution

✓ **NOTE:** Exit Criteria for Phase 0: All tools responding correctly, Base64 samples verified, RSA keys generating and validating successfully, all 3 source systems confirmed registered in TrackWizz.

PHASE 1

Field Level Validation (Atomic Testing)

Objective: Validate every single field in isolation — data type, length, format, mandatory rules, enum values, and boundary conditions. Change only the field under test; all other fields remain valid. **Duration:** 3 Weeks | **Test Cases:** ~580 | **Priority:** CRITICAL

1.1 HTTP Header Fields (~21 test cases)

Fields: ApiToken, Cluster, Domain (I)

ApiToken:

- Valid static token → HTTP 200
- Missing ApiToken header → rejection
- Empty string value → rejection
- Expired/invalid token → 401
- Token with special characters → behavior
- Case sensitivity validation

Cluster:

- Value = 'CL1_User' → valid
- Wrong value e.g. 'CL2_User' → behavior
- Missing Cluster header → behavior
- Case sensitivity: 'cl1_user' vs 'CL1_User'

Domain (I):

- Valid tenant URL → valid
- Wrong tenant URL → rejection
- Missing domain header → behavior
- HTTP vs HTTPS domain → behavior

1.2 Main Request Fields (~25 test cases)

requestId:

- Valid unique alphanumeric ID
- Missing requestId → request rejection
- Empty string → rejection
- Duplicate requestId (same request, two records)
- Special characters in requestId
- Extremely long requestId (MAX boundary)

sourceSystemName:

- Valid registered source system → accepted
- Unregistered name → MRV rejection (response: null)
- Missing sourceSystemName → validationCode MRV10
- Empty string → rejection

- Case sensitivity test (Finacle vs finacle)
- Source system with spaces

purpose:

- Valid '09' → accepted
- Missing purpose → rejection
- Wrong value '08' or '10' → rejection
- Numeric 9 vs string '09'
- Empty string
- Null value

1.3 — 1.4 Identity & Name Fields (~60 test cases)

- constitutionType: All valid Individual codes (1,5,7,27), all LE codes, invalid code 999, missing, empty, string vs numeric
- status: All valid enum values (Active, Closed, Dormant, InActive, Suspended), invalid value, case sensitivity
- prefix: All valid values (Mr, Ms, Mrs, Miss, Dr, Mx), invalid prefix, missing, case sensitivity test
- firstName: Standard name, single character, 50-char boundary, 51-char over-boundary, numbers in name, special characters, only spaces, missing
- Regional name variations: South Indian single names, names with apostrophe (O'Brien), hyphenated names (Mary-Anne)
- Subjective family name logic: fatherFirstName requires fatherPrefix; at least one of Father/Spouse/Mother is mandatory
- Combination matrix: Only father provided, only spouse, only mother, all three, none (should fail)

1.5 Date Fields (~55 test cases)

effectiveDate (format: DD-MMM-YYYY):

- Valid: 01-Jan-2025
- DD/MMM/YYYY alternate format
- DD-MM-YYYY → format error expected
- Future date → behavior
- Leap year: 29-Feb-2024 (valid) vs 29-Feb-2023 (invalid)
- Invalid: 32-Jan-2025, 01-ABC-2025
- Missing → fail

dateOfBirth:

- Valid DOB
- Future DOB → fail
- DOB making age 0 (newborn) → boundary
- DOB making age 150 → impossible
- DOB = today → behavior
- DOB inconsistent with minor='1' flag → domain conflict test

kycDateOfDeclaration vs kycVerificationDate:

- kycVerificationDate before kycDateOfDeclaration → behavior (logical inconsistency)

- Both as future dates → behavior
- kycDateOfDeclaration before customer DOB → behavior

1.6 Address Fields (~120 test cases)

- permanentAddressCountry: IND (valid), all 3-digit ISO codes, invalid code, 2-digit code (Alpha-2 wrong format)
- permanentAddressZipCode: Valid 6-digit PIN, 10-char max, 11-char over-boundary, alphanumeric PIN, all zeros (000000)
- permanentAddressLine1/2/3: Valid text, 55-char boundary, 56-char over-boundary, special chars (#, -,), only spaces, missing Line1
- permanentAddressState: All valid state codes including new UTs (LA=Ladakh, DNHDD), OTH, invalid code
- permanentAddressDocument: All valid Individual applicable codes, LE-only code for Individual → fail
- correspondenceAddressDocument: DeemedPOA codes (UtilityBill2m, PropertyTax, etc.) — only valid for correspondence
- All correspondence address fields mirror permanent address test cases
- Geographic edge cases: Post-bifurcation states (Telangana/AP), merged UTs (DNHDD), UT status changes (J&K;)

1.7 Conditional Document ID Fields (~80 test cases)

- passportNumber: Required when permanentAddressDocument OR correspondenceAddressDocument = 'Passport'. Missing → fail. Length = 40 (boundary). Length = 41 → fail
- voterIdNumber: Required when document = 'VoterID'. Old format vs new format. State-specific prefix validation
- aadhaarNumber: Required for AadhaarCard/EKYCAuthImage/AadhaarOffline. Last 4 digits only. Starting with 0 (e.g., 0123). 3 digits → fail. 5 digits → fail
- aadhaarVaultReferenceNumber vs aadhaarNumber: Mutual exclusivity — provide one OR the other, not both
- drivingLicenseNumber: Required when document = 'DrivingLicense'. Old pre-Sarathi format vs new 15-digit format
- nregaNumber: Required only when document = 'NREGA'. Length = 40 boundary
- nprLetterNumber: Required only when document = 'NPRLetter'
- nationalid: Required when correspondenceAddressDocument = 'ForeignNationalID'

1.8 PAN & FormSixty Mutual Exclusion Logic (~30 test cases)

■ **WARNING: CRITICAL DOMAIN FINDING:** The API documentation states PAN 4th character must be 'P' (individual). However, for Legal Entities: Companies use 'C', HUF uses 'H', Firms use 'F', AOP uses 'A'. These non-'P' PANs must be tested to identify if the API incorrectly rejects valid LE PANs.

- formSixty='0' + valid PAN (4th char='P' for individual) → valid
- formSixty='1' + no PAN → valid (Form 60 declaration)
- formSixty='0' + no PAN → behavior (should fail)
- formSixty='1' + PAN present → business rule conflict
- Both formSixty and PAN missing → behavior

- PAN format: ABCPE1234F → valid | abcpe1234f (lowercase) → behavior
- PAN length = 9 → fail | PAN length = 11 → fail
- LE PAN with 4th char = 'C' (Company) → verify system behavior
- LE PAN with 4th char = 'H' (HUF) → verify system behavior
- Minor customer + formSixty → regulatory expectation

1.9 KYC Attestation Type Matrix (~40 test cases)

Code	Name	Individual	LE	Related Party
1	Certified Copies	✓	✓	✓
2	E-KYC Data from UIDAI	✓	✗ FAIL	✓
3	Offline Verification	✓	✗ FAIL	✓
4	Digital KYC Process	✓	✗ FAIL	✓
5	Equivalent E-Document	✗ FAIL	✓	✗ FAIL
6	Video KYC	✓	✗ FAIL	✗ FAIL

1.10 Minor, Disability & Demise Fields (~35 test cases)

- minor='0' + DOB age 18+ → valid
- minor='1' + DOB age < 18 → valid
- minor='0' + DOB age < 18 → CONFLICT — domain behavior must be defined
- minor='1' + DOB age 18+ → CONFLICT — domain behavior must be defined
- minor='Yes'/'No' instead of '0'/'1' → fail
- personWithDisability='1' + typeOfDisability (all 20 codes tested) → valid
- udidNumber length = 18 (boundary) and length = 19 (over-boundary)
- demiseDate provided + ckyclId present → valid
- demiseDate provided + ckyclId MISSING → fail (documented rule)
- demiseDate = future date → fail
- demiseDate before customer dateOfBirth → fail (impossible scenario)
- demiseDate without Death Certificate document → behavior

1.11 Legal Entity Specific Fields (~50 test cases)

- dateOfBirth = Incorporation Date for LE (not personal DOB)
- commencementDate cannot be before dateOfBirth (incorporation date)
- commencementDate = dateOfBirth → valid or invalid? (edge case)
- countryOfBirth = Country of Incorporation — mandatory for LE
- birthCity = City of Incorporation — mandatory for LE
- proofOfIdSubmitted = 'CIN' → companyIdentificationNumber becomes mandatory
- proofOfIdSubmitted = 'CRN' → companyRegistrationNumber becomes mandatory
- permanentAddressDocument for LE — only 'NonIND applicable' values per enum 7.28
- permanentAddressDocument = 'Others' → permanentAddressDocumentOthersValue mandatory
- correspondenceAddressDocument for LE is 'No' (optional) — test with and without
- kycAttestationType = '5' (Equivalent E-Document) only for LE — verify

- gender field for LE should be blank — test with and without value

1.12 Related Party Specific Fields (~30 test cases)

- citizenships mandatory for Related Party — missing → fail
- citizenships = IND → valid | invalid country code → fail
- directorIdentificationNumber NOT provided when relationCode ≠ '106' (Director) → valid
- directorIdentificationNumber NOT provided when relationCode = '106' (Director) → fail
- sourceSystemName in RP must match the parent request sourceSystemName
- ekycOTPbased mandatory for RP — '0' and '1' both tested
- prefix mandatory for RP — all valid values tested
- RP constitutionType = LE-type code (non-Individual) → behavior when RP is expected to be Individual

PHASE 2

Object Level Validation (Structural Testing)

Objective: Validate the structure and completeness of each JSON object block. Test how each object behaves as a unit — empty, null, malformed, nested incorrectly, or with wrong cardinality. **Duration:** 2 Weeks | **Test Cases:** ~160 | **Priority:** CRITICAL

2.1 customerList Object (~25 test cases)

- Empty customerList [] → behavior (should fail or warn)
- Single customer → standard scenario
- Multiple customers: 2, 5, 10, 50, 100 records in one request
- Mix of Individual + Legal Entity in same customerList
- customerList not an array (object instead) → fail
- Null customerList → fail | Missing customerList key → fail

2.2 documentList Object (~35 test cases)

- documentList not provided (null) → valid (it is optional)
- Empty documentList [] → behavior
- Single document | Multiple documents (2, 5, 10)
- Duplicate documentID in same list → fail
- documentCode not matching customer type (e.g., MOA for Individual) → fail
- document field (Base64) empty → fail | Invalid Base64 → behavior
- Very large Base64 document (5MB photograph) → performance behavior
- Same documentCode submitted twice → behavior

2.3 taxDetailDtoList Object (~25 test cases)

- Not provided → valid (optional for LE, not applicable for Individual)
- taxDetailDtoList for Individual record → behavior
- Single tax record with IND → valid
- Multiple tax records — same country twice → behavior
- Multiple foreign tax residencies → valid (FATCA/CRS multi-country scenario)
- taxResidencyEndDate before taxResidencyStartDate → fail
- taxIdentificationNumber missing → fail (mandatory field)

2.4 relatedPersonList Object (~25 test cases)

- Not provided → valid (optional)
- Empty array → behavior
- Single related person | Multiple related persons
- RP without corresponding customerRelationDtoList entry → behavior
- Same RP sourceSystemCustomerCode appearing twice → behavior
- relatedPersonList attached to an Individual customer → behavior (should not apply)

2.5 customerRelationDtoList Object (~30 test cases)

- Not provided → valid (optional)
- Linkage referencing a customerSourceSystemCode not in this request → fail
- Linkage referencing a relatedPersonSourceSystemCode not in this request → fail
- requestId in linkage ≠ parent requestId → fail
- Duplicate relation: same customer + RP + same relationCode → behavior
- Circular relation: Customer A → RP B AND Customer B → RP A in same request → behavior
- Self-relation: customer relates to itself → fail
- Multiple different relation codes between same customer and RP → behavior
- relationStartDate = future date → fail (documented rule)
- relationEndDate before relationStartDate → fail

2.6 Full Request Structure (~20 test cases)

- Valid minimal request (only mandatory fields populated) → accepted
- Valid complete request (all fields including all 'No' fields) → accepted
- Unknown/extra fields in request → behavior (strict vs lenient parsing)
- Wrong JSON structure (array at root level instead of object) → fail
- Empty JSON body {} → fail | Null request body → fail
- XML payload instead of JSON → fail (Content-Type mismatch)
- Malformed JSON (missing closing bracket, extra comma) → fail

PHASE 3

Business Rule & CKYC Domain Validation

Objective: Validate all CKYC regulatory business rules, cross-field dependencies, and domain-specific logic mandated by CERSAI, RBI KYC Master Directions, and PMLA. These are the most critical tests from a regulatory compliance perspective. **Duration:** 3 Weeks | **Test Cases:** ~210 | **Priority:** CRITICAL

3.1 ConstitutionType Business Rules (~60 test cases)

- Type 1 (Individual): ekycOTPbased is mandatory, gender is mandatory, Father/Spouse/Mother required
- Type 2 (HUF): Karta (relationCode=111) expected as Related Party — test without Karta
- Type 5 (NRI): Foreign address document rules — test with Indian-only documents
- Type 7 (Foreign National): correspondenceAddressDocument = 'ForeignNationalID' triggers nationalid mandatory
- Type 9 (Trust): Trustee, Settlor, Beneficiary relation chain expected — test incomplete chain
- Type 11 (LLP): Designated Partner (relationCode=DesignatedPartner) expected
- Type 17 (Partnership): Partner (relationCode=119) expected
- Type 29/30 (Public/Private Ltd): Director + proofOfIdSubmitted='CIN' expected
- Type 101 (Sole Proprietorship): Proprietor relation expected
- Type 18 (AOP/BOI): Members of AOP (relationCode=198) expected
- Test submitting LE-only constitutionType (e.g., 8=Mutual Fund) with Individual field set
- Test submitting Individual constitutionType (1) with LE-specific fields populated

3.2 Address Document Cross-Rules (~35 test cases)

- DeemedPOA documents (UtilityBill2m, PropertyTax, PensionOrder, EmployerHouseLetter, CKYCSelfDeclaration) → valid ONLY for correspondenceAddressDocument, NEVER for permanent
- ForeignNationalID → valid ONLY for correspondenceAddressDocument
- For LE: permanentAddressDocument must use 'NonIND applicable' values — test IND-only docs for LE permanent address
- permanentAddressDocument = 'Others' → permanentAddressDocumentOthersValue must be present
- Same document type used for both permanent and correspondence → behavior
- IND customer (constitutionType=1) using LE-only document codes (CIN, CRN, MOA) → fail

3.3 CKYC Submission Regulatory Rules (~30 test cases)

- purpose must always be '09' for CKYC Initial Submission — any other value rejected
- sourceSystemName must be pre-registered in TrackWizz — unregistered causes request-level rejection
- requestId must be unique per record — test duplicate requestIds and their response behavior
- effectiveDate for LE must NOT be a future date (documented constraint)
- commencementDate must not be older than dateOfBirth for LE records
- demiseDate requires ckycId — test demise without ckycId (must fail)
- demiseDate before customer dateOfBirth — impossible scenario, should fail
- ckycNumber field: 14-digit exact length validation
- Submission with existing ckycNumber present in request — update vs new creation behavior

- CKYC record with identical PAN submitted by two different source systems — deduplication behavior

3.4 Related Party Linkage Business Rules (~30 test cases)

- requestId in customerRelationDtoList must match the parent request requestId — mismatch → fail
- customerSourceSystemCode must exist in the customerList of the same request
- relatedPersonSourceSystemCode must exist in the relatedPersonList of the same request
- relationStartDate cannot be a future date (documented rule)
- relationStartDate cannot predate the customer's dateOfBirth
- relationEndDate, when provided, must be after relationStartDate
- relationCode = 106 (Director) → directorIdentificationNumber mandatory in RP record
- Guardian relation → the customer being linked must have minor='1'
- Karta relation (111) → linked entity must have constitutionType = 2 (HUF)
- shareHoldingPercentage format and range validation (0-100%)

3.5 Response Business Rules (~30 test cases)

- Request-level rejection: response field = null, validationCode and validationDescription populated
- Record-level rejection: overallStatus = 'RejectedByTW', purposeResponse populated with codes
- Full success: overallStatus = 'AcceptedByTW', purposeResponse with purposeCode='09', validationFailureCount=0
- Multiple field failures in one record — verify ALL failures reported (not just first)
- Customer record succeeds + RP record fails → what is overallStatus? (Expected: RejectedByTW)
- Customer fails + RP linkage succeeds → overallStatus behavior
- validationFailureCount must numerically match the number of individual validation failures listed
- data field in purposeResponse must be null/blank for purpose code '09'
- relatedPersonResponse = null when no RP submitted (verify not empty array)
- documentResponseList = null when no documents submitted

3.6 CKYC Regulatory Compliance Edge Cases (~25 test cases)

■ **WARNING:** These scenarios represent the highest regulatory risk. A failure here constitutes a compliance violation, not merely a technical bug.

- PEP (Politically Exposed Person): politicallyExposed field behavior and impact on processing
- FATCA/CRS: Foreign national with multiple tax residencies in taxDetailDtoList
- NRI customer (type 5) submitting with Indian address documents — CERSAI acceptability
- Foreign National (type 7) without ForeignNationalID as correspondence document — should fail
- Minor customer (minor='1') with kycAttestationType='6' (Video KYC) — regulatory concern, should this be permitted?
- UBO (Ultimate Beneficial Owner, relationCode=130) — shareholding percentage validation
- globalIntermediaryIdentificationNumber for Foreign Portfolio Investors (constitutionType=14)
- HUF customer without Karta — what does CERSAI expect vs what TrackWizz accepts?
- Trust without all three roles (Trustee + Settlor + Beneficiary) — CERSAI requirement vs API behavior

- PMLA AML Risk fields (regAMLRisk, regAMLRiskLastRiskReviewDate) — 'No' field but regulatory significance

PHASE 4

API Contract & Protocol Testing

Objective: Validate the API as an HTTP service — method compliance, content types, response codes, schema conformance, and URL structure. Ensure the API behaves correctly at the protocol level independent of business logic. **Duration:** 1 Week | **Test Cases:** ~70 | **Priority:** HIGH

4.1 HTTP Method Testing (~10 test cases)

- POST → 200/accepted (correct method)
- GET → 405 Method Not Allowed
- PUT → 405
- DELETE → 405
- PATCH → 405
- OPTIONS → CORS headers behavior

4.2 Content-Type Testing (~8 test cases)

- application/json → valid
- text/plain → 400 or rejection
- application/xml → 415 Unsupported Media Type
- Missing Content-Type header → behavior
- multipart/form-data → rejection

4.3 HTTP Response Code Validation (~15 test cases)

- 200 with valid request → AcceptedByTW or RejectedByTW
- 400 → Bad request for malformed body
- 401 → Invalid/missing ApiToken
- 403 → Valid token but wrong tenant/cluster
- 404 → Wrong endpoint path
- 405 → Wrong HTTP method
- 500 → Server error simulation (if test env permits)
- Response time < 2 seconds for single record (SLA baseline)

4.4 Response Schema Validation (~20 test cases)

- Success response contains all documented fields: requestId, validationCode, validationDescription, response
- response object contains: overallStatus, customerResponse
- customerResponse contains: sourceSystemCustomerCode, applicationRefNumber, validationOutcome, purposeResponse
- purposeResponse contains: purpose, purposeCode, data, validationCode, validationDescription, validationFailureCount
- Data types match: validationFailureCount is Int (not String)
- Null fields present as null (not absent)

- No undocumented fields appearing in response
- Empty arrays vs null distinction verified

4.5 Endpoint & URL Testing (~10 test cases)

- Correct path works: /CustomerInfo/as501
- Wrong path → 404
- HTTP vs HTTPS → redirect or direct rejection
- Trailing slash in URL → behavior
- URL case sensitivity

4.6 Request Payload Size Testing (~7 test cases)

- Minimal payload (only mandatory fields, no documents) — fast response
- Standard payload (all fields, 1 Photograph document)
- Large payload (5 documents including high-res images)
- Oversized payload (20 documents, total > 10MB) → behavior
- Empty body → 400
- Body with only whitespace → 400

PHASE 5

Integration & End-to-End Testing

Objective: Validate complete real-world submission journeys from request construction through response validation. Test complete record types as they would be submitted by real Financial Institutions. **Duration:** 2 Weeks | **Test Cases:** ~110 | **Priority:** HIGH

5.1 Individual Complete Journeys (~30 test cases)

- Minimal valid Individual (only mandatory fields) → AcceptedByTW
- Complete Individual with ALL fields populated → AcceptedByTW
- Individual + Photograph document only
- Individual + Photograph + AadhaarCard images
- Individual + Photograph + VoterID (both address docs)
- Individual (NRI, constitutionType=5) complete submission
- Individual (Foreign National, constitutionType=7) with ForeignNationalID
- Individual (Minor, minor='1') complete submission with guardian RP
- Individual with disability (personWithDisability='1', all disability fields)
- Individual demise update: kycId + demiseDate + Death Certificate

5.2 Legal Entity Complete Journeys (~25 test cases)

- Minimal valid LE (Sole Proprietorship, constitutionType=101)
- Private Limited Company (type=30) with CIN + Board Resolution + MOA
- Trust (type=9) with Trust Deed document
- HUF (type=2) complete submission
- Partnership Firm (type=17) complete submission
- LLP (type=11) complete submission
- LE with taxDetailDtoList (IND tax residency)
- LE with taxDetailDtoList (multiple foreign tax residencies — FATCA scenario)

5.3 Legal Entity + Related Party Full Journey (~25 test cases)

- LE + 1 Director (complete with DIN, all mandatory RP fields)
- LE + Multiple Directors (3 directors scenario)
- LE + Director + Shareholder (2 relation types)
- LE (HUF) + Karta
- LE (Trust) + Trustee + Beneficiary + Settlor
- LE + RP + full customerRelationDtoList with all optional linkage fields
- LE + RP with RP document list (Photograph + AadhaarCard + Passport)

5.4 Multi-Record Request Journey (~15 test cases)

- 2 Individuals in one request → both accepted
- 1 Individual + 1 LE in same request → both accepted

- 1 valid Individual + 1 invalid Individual → partial success, mixed response
- 10 records (mix of types) → response correctly maps to each customer
- All records fail → overallStatus = RejectedByTW for all

5.5 Response Structure End-to-End Validation (~15 test cases)

- Full success response — validate every field in nested response structure
- Request-level rejection — confirm response = null, codes populated
- Record-level rejection — confirm purposeResponse structure matches spec
- RP failure in complex LE+RP request — relatedPersonResponse structure validated
- Linkage failure — relatedPersonRelationResponse structure and fields validated
- Mixed results (customer success + RP fail) — overall response structure validated

PHASE 6

Security & Encryption Testing

Objective: Validate encryption integrity, digital signature verification, API authentication security, data exposure prevention, and resistance to common attack vectors. Mandatory for an API handling national-scale PII data. **Duration:** 2 Weeks | **Test Cases:** ~85 | **Priority:** HIGH

6.1 Encryption Integrity (~25 test cases)

- Valid AES-256 + RSA-2048 full round trip → decrypts correctly
- Valid AES-256 + RSA-1024 → decrypts correctly (1024-bit is documented as supported)
- AES session key 256-bit (not 128-bit) — note: document mentions 'Symmetric 128 bits' — verify actual implementation
- Tampered EncryptedData (modify 1 byte) → decryption failure, meaningful error
- Wrong EncryptionKey (different RSA key) → failure, no data leakage
- Missing Signature field → rejection
- Invalid Signature (tampered) → rejection — signature verification must fail
- Signature verified with wrong public key → fail
- Replay attack: identical encrypted request resent → idempotency or replay rejection
- Unsupported key size (512-bit) → rejection with appropriate error

6.2 Sensitive Data Protection (~15 test cases)

- PAN number must NOT appear in error messages or validation descriptions
- Aadhaar last 4 digits must NOT be exposed in response error text
- ApiToken must NOT be echoed in any response
- Error messages must not reveal internal system architecture or stack traces
- Response headers must not expose server version, framework, or technology stack

6.3 Injection Attack Testing (~20 test cases)

- SQL injection in firstName: ' OR 1=1; DROP TABLE customers; --
- JSON injection in address fields: {"injected": "malicious"}
- Script injection in email: alert('xss')@domain.com
- Null byte injection: firstName = 'John\0 DROP TABLE'
- Unicode injection: special Unicode control characters in name fields
- Oversized field injection: 10,000 character firstName (buffer overflow attempt)
- CRLF injection in header fields

6.4 Authentication & Authorization (~15 test cases)

- No ApiToken → 401 Unauthorized
- Invalid/random ApiToken → 401
- ApiToken from different tenant/environment → 403 Forbidden
- Valid ApiToken + wrong Cluster value → behavior (expected: rejection)

- ApiToken enumeration resistance — sequential tokens should not work
- Token replay after expiry → 401

6.5 Rate Limiting & DoS Resistance (~10 test cases)

- 100 identical requests/second → rate limiting behavior observed
- Same requestId submitted 1,000 times → idempotency validation
- Extremely large Base64 document (50MB) → rejection or timeout without crash
- Deeply nested JSON objects → parser protection validation

PHASE 7

Performance & Load Testing

Objective: Validate API performance under realistic Indian banking load conditions. India's banking ecosystem generates surge loads at financial year-end, RBI deadline days, and IPO seasons that must not degrade service quality. **Duration:** 2 Weeks | **Test Cases:** ~55 | **Priority:** MEDIUM

Performance SLA Targets

Scenario	Target Response Time	Max Acceptable
Single record, no documents	< 1 second	2 seconds
Single record + documents	< 3 seconds	5 seconds
100 concurrent requests	< 2 seconds avg	5 seconds P99
1,000 concurrent requests	< 5 seconds avg	10 seconds P99
Peak load (5,000 concurrent)	< 10 seconds avg	No crashes

7.1 Baseline Performance (~10 test cases)

- Single request without documents: response time measurement (10 sequential runs)
- Single request with Photograph only: response time measurement
- Single request with full document set (5 docs): response time
- Encrypted request round-trip: AES+RSA overhead measurement
- Response time consistency check: 10 identical requests, standard deviation analysis

7.2 Load Testing (~15 test cases)

- 100 concurrent users: avg response time, error rate
- 500 concurrent users: avg response time, error rate
- 1,000 concurrent users: avg response time, P95, P99
- 5,000 concurrent users: max load — banking peak simulation
- Gradual ramp-up: 10 → 100 → 500 → 1000 users over 30 minutes

7.3 Stress & Recovery Testing (~10 test cases)

- Ramp to breaking point: identify max throughput before errors
- Recovery after overload: response time normalization after load drops
- Sustained load: 2-hour continuous at 500 concurrent — memory leak detection
- CPU spike behavior: system stability under 100% CPU utilization

7.4 Indian Banking Peak Scenarios (~10 test cases)

- Month-end surge: 10x normal load for 2-hour window
- Financial year-end (March): sustained high load for full business day simulation
- Post-RBI KYC deadline: spike from all banks simultaneously

- IPO season: Demat account KYC surge pattern

7.5 Volume Testing (~10 test cases)

- 10,000 record batch: single request with 10,000 customers
- 100,000 records submitted sequentially over 1 hour
- Large document payloads at scale: 1,000 records each with 3 documents

PHASE 8

Production Simulation & Chaos Testing

Objective: Simulate real production conditions including legacy banking data patterns, CBS migration scenarios, infrastructure failures, and unexpected edge cases from India's diverse banking ecosystem.

Duration: 2 Weeks | **Test Cases:** ~125 | **Priority:** MEDIUM

8.1 Real Banking Data Patterns (~30 test cases)

These tests simulate data patterns found in real Indian banking systems that synthetic test data cannot replicate:

- South Indian single-name customers: firstName='Murugan', lastName="" (empty) → valid
- Tamil convention: father's name as surname — 'Rajesh Krishnamurthy' format
- Names with initials: firstName='S.', lastName='Venkataraman' → behavior
- Very long South Indian names: 'Thiruvengadamudhaliar' (21 chars) — within 50-char limit
- Northeast Indian names with Christian + tribal surname combinations
- Muslim names with 'Md.' abbreviation in firstName
- Names with 'S/O' or 'D/O' embedded (old legacy data entry)
- Rural addresses: Village + Post Office + District format in address lines
- Survey number as address (South India): 'Survey No. 123/4' in addressLine1
- Khasra number format (North India): 'Khasra 456, Village XYZ'
- Customers with no mobile number and no email (rural bank customers)
- Customers with no PAN (Form 60 customers — common in rural India)
- Accounts opened pre-2009 before Aadhaar existed: aadhaarNumber = empty
- Very old customers: dateOfBirth = '01-Jan-1920' (age 100+) → valid
- Legacy default DOB: '01-Jan-1900' (common CBS default) → validation behavior

8.2 CBS Data Migration Scenarios (~25 test cases)

- Finacle 7.x: Date format DD/MM/YYYY needs conversion — test with unconverted dates
- Oracle FlexCube: Customer codes sometimes contain special characters like '/' or '-'
- FinnOne: Numeric-only customer IDs vs alphanumeric sourceSystemCustomerCode
- TCS BaNCs: Different address line mapping — data may appear in unexpected fields
- Trailing spaces in field values (e.g., firstName = 'RAMESH ') — common in legacy exports
- Null characters (\0) embedded in string fields from EBCDIC conversions
- ALL CAPS names from older CBS systems: 'RAMESH KUMAR SHARMA' → behavior
- Mixed case inconsistencies: 'rAmEsH kUmAr' → behavior
- Tab characters embedded in address fields from legacy exports
- ISO-8859-1 encoded data with diacritical marks converted to UTF-8

8.3 Chaos Engineering Scenarios (~20 test cases)

■ **WARNING:** Chaos testing must be conducted in isolated test environment only. Never execute chaos tests against production or shared UAT environments.

- CERSAI endpoint unavailable (simulated): TrackWizz behavior — queue, fail, or timeout?
- Encryption service timeout: API behavior when encryption takes > 30 seconds
- Database connection lost mid-request processing: response behavior and data integrity
- Network timeout after request accepted but before response sent: retry behavior
- Partial response scenario: connection dropped mid-response — client retry safety
- Disk space exhaustion simulation: behavior when log disk is full
- Memory pressure scenario: behavior at 90% heap utilization
- Certificate expiry simulation: behavior when RSA certificate expires

8.4 Regression Suite (~50 test cases)

Selected critical test cases from Phases 1, 3, and 5 are re-executed as a regression suite after any code fix, deployment, or configuration change:

- All mandatory field validation tests (Phase 1 critical subset)
- All CKYC domain business rules (Phase 3 complete)
- All happy path E2E journeys — Individual, LE, RP, Linkage (Phase 5)
- Encryption round-trip test (Phase 6 critical)
- Response structure validation (Phase 4 schema tests)
- Any test case previously associated with a production defect

PHASE 9

CERSAI Integration Validation

Objective: Test against the ACTUAL CERSAI sandbox environment — not a mock or stub. Validate that records submitted via TrackWizz successfully register at CERSAI and that CERSAI responses are correctly mapped and returned. **Duration:** 2 Weeks | **Test Cases:** ~100 | **Confidence Gained:** +5%

■ **CRITICAL:** TrackWizz can accept a record but CERSAI may still reject it. This silent failure scenario is the most dangerous production risk — an FI receives success but the CKYC is never registered. This phase specifically tests for this scenario.

CERSAI Sandbox Submission Tests

- Submit 1,000 Individual records to CERSAI sandbox — verify CKYC numbers returned
- Submit 200 Legal Entity records — verify LE CKYC numbers
- Submit 100 records with Related Parties — verify linkage registered at CERSAI
- Submit intentionally invalid records — confirm CERSAI rejection codes map correctly in TrackWizz response

CERSAI Deduplication Tests

- Submit same customer (same PAN) twice from same source system — CERSAI deduplication behavior
- Submit same customer from two different source systems — cross-FI deduplication
- Submit customer with CKYC number already registered at CERSAI — update vs rejection behavior
- Submit customer whose Aadhaar + DOB + Name matches existing CERSAI record

CERSAI Response Mapping Tests

- Verify CKYC number format (14 digits) in all success responses
- Verify CERSAI rejection codes are correctly translated to TrackWizz validationDescription
- Test CERSAI SLA: response time from submission to CKYC number generation
- Test CERSAI weekend/holiday behavior — queue or immediate failure?

Pilot Bank UAT (User Acceptance Testing)

Objective: Conduct UAT with a real Financial Institution using actual (anonymized) customer data from their Core Banking System. This phase discovers data quality issues, CBS-specific formatting problems, and business process mismatches impossible to find with synthetic test data. **Duration:** 4 Weeks | **Exploratory Scenarios:** ~200 | **Confidence Gained:** +8%

Pilot Bank Selection Criteria

- Small bank — manageable volume (50,000-500,000 customers) for controlled testing
- Mix of customer types: Individuals, Small Business entities, a few LEs
- Different CBS from Finacle preferred (e.g., Oracle FlexCube, FinnOne, or custom)
- Technically capable team willing to participate in joint testing sessions
- Regulatory standing: bank must be in good standing with RBI
- Data privacy compliance: bank must provide anonymized/masked data

Week 1 — Data Extraction & Preparation

- Bank extracts 10,000 customer records (anonymized — real names replaced, real formats preserved)
- Records include: 8,000 Individuals, 1,500 Small Business LEs, 500 with Related Parties
- Data anonymization validated: no real PAN, Aadhaar, or mobile numbers in test data
- TrackWizz team maps bank CBS fields to AS501 API fields
- Data transformation script developed and reviewed

Week 2 — Initial UAT Run

- Submit all 10,000 records via AS501 API in UAT environment
- Categorize outcomes: Accepted, Rejected (by TrackWizz), Rejected (by CERSAI sandbox)
- Target: <5% rejection rate before issue fixing
- Document every rejection with full field-level analysis
- Identify patterns in rejections: systematic issues vs one-off data problems

Week 3 — Issue Resolution & Rerun

- Fix all systematic issues discovered (API logic, field mapping, enum mismatches)
- Provide data correction guidance to bank for data quality issues
- Resubmit corrected records
- Target: <0.5% rejection rate after fixes
- Document all discovered edge cases and add to regression suite

Week 4 — Sign-Off & Documentation

- Bank team validates that accepted records are correctly registered at CERSAI sandbox
- Formal UAT sign-off document prepared
- All discovered issues documented with resolution status
- Test cases derived from real data issues added to permanent regression suite

- Bank-specific CBS integration guide drafted for future onboarding

✓ **NOTE:** UAT Exit Criteria: <1% overall rejection rate, all systematic issues resolved, bank team formal sign-off obtained, CERSAI sandbox confirms successful registrations.

PHASE 11

Independent Security Audit

Objective: External penetration testing and security audit by a CERT-In empanelled security auditor. Mandatory for financial APIs under RBI IT Framework and essential for FI procurement approval.

Duration: 2 Weeks | **Confidence Gained:** +4%

- OWASP API Security Top 10 validation (Broken Object Level Auth, Excessive Data Exposure, etc.)
- Full API penetration testing by certified ethical hacker
- Encryption implementation audit — key management, algorithm correctness, IV handling
- Token security assessment — ApiToken entropy, rotation policy, revocation
- Data exposure vulnerability scan — PAN/Aadhaar leakage in logs, errors, responses
- RBI Cybersecurity Framework compliance check (June 2016 circular)
- DPDP Act 2023 compliance: data minimisation, purpose limitation, retention
- Formal security assessment certificate issued for regulator submission

PHASE 12

Observability & Runbook Validation

Objective: Validate that production issues can be detected within minutes, diagnosed with full context, and resolved using documented runbooks. **Duration:** 1 Week | **Confidence Gained:** +1%

- Every API call logged with: requestId, sourceSystemName, timestamp, response time, outcome
- Alerting configured: error rate > 5% → immediate alert | response time > 5s → warning
- CERSAI connectivity monitoring: alert within 60 seconds of connectivity loss
- Runbook tested: 'API is down' — steps validated, RTO < 15 minutes confirmed
- Runbook tested: 'Mass rejection from specific bank' — diagnosis steps validated
- Runbook tested: 'CERSAI unreachable' — queue management and FI communication steps
- Audit trail: every submission traceable end-to-end with encrypted request/response stored
- 7-year data retention policy for PMLA compliance confirmed and tested

PHASE 13

Canary / Shadow Production Release

Objective: Release to production with controlled traffic management and instant rollback capability. Build real-world confidence before full production scale. **Duration:** 4 Weeks | **Confidence Gained:** +7% → Target: 98%

Weeks 1-2: Shadow Mode

- Real production traffic duplicated — API runs in parallel with existing system
- No actual CERSAI submissions — compare expected behavior vs actual
- All discrepancies documented and resolved before live traffic

Week 3: Canary Release (5% traffic)

- One small bank → live submissions to CERSAI production
- War room active during business hours with TrackWizz + bank team
- Every record monitored individually — immediate rollback if error rate > 1%

Week 4: Limited Release (25% traffic)

- 3-5 small banks live on production
- Performance baselines confirmed against actual production load
- Incident response procedures tested in real conditions
- Full production release approved based on metrics

Complete Test Case Count Summary

Phase	Name	Test Cases	Duration	Priority
0	Foundation & Environment Setup	~20	1 Week	BLOCKER
1	Field Level Validation (Atomic)	~580	3 Weeks	CRITICAL
2	Object Level Validation (Structural)	~160	2 Weeks	CRITICAL
3	Business Rule & CKYC Domain	~210	3 Weeks	CRITICAL
4	API Contract & Protocol	~70	1 Week	HIGH
5	Integration & End-to-End	~110	2 Weeks	HIGH
6	Security & Encryption	~85	2 Weeks	HIGH
7	Performance & Load	~55	2 Weeks	MEDIUM
8	Production Simulation & Chaos	~125	2 Weeks	MEDIUM
9	CERSAI Integration Validation	~100	2 Weeks	HIGH
10	Pilot Bank UAT	~200*	4 Weeks	CRITICAL
11	Independent Security Audit	Ext. Audit	2 Weeks	CRITICAL
12	Observability & Runbook	~30	1 Week	HIGH
13	Canary / Shadow Release	Live Monitor	4 Weeks	CRITICAL

TOTAL (Phase 0-10 + 12)	~1,745 test cases	26 Weeks
-------------------------	-------------------	----------

* Phase 10 (Pilot Bank UAT) test cases are exploratory in nature. Count grows with each bank onboarded. Target: 3,000+ test cases by end of Year 1 as more FIs are onboarded.

Test Case Growth Roadmap

Timeline	Test Cases	Confidence	Milestone
Phase 0-3 Complete	~970	70%	Core validation done
Phase 0-8 Complete	~1,415	78-82%	Pre-pilot readiness
Phase 9-10 Complete	~1,715	91%	CERSAI + real data validated
Phase 11-13 Complete	~1,745+	98%	Production release approved
End of Year 1	3,000+	99%+	10+ banks onboarded, battle-tested

Production Readiness Golden Rules

Rule 1: Never Skip Phase 0	A bad test environment produces misleading results. Every defect found in a broken environment wastes time and erodes confidence in the testing process itself.
Rule 2: Always Test Both Encrypted & Decrypted	The business logic must be validated on decrypted payloads. The encryption layer must be separately validated. Both paths are critical and cannot substitute for each other.
Rule 3: CKYC Domain Rules Override API Documentation	When API documentation and CERSAI regulatory requirements conflict, CERSAI requirements prevail. Always cross-reference with the current RBI KYC Master Directions.
Rule 4: Real Data Beats Synthetic Data	Synthetic test data cannot replicate 30 years of Indian banking data inconsistencies. Always include regional name patterns, legacy CBS formats, and linguistic variations.
Rule 5: Zero Tolerance — Both Directions	False acceptance of invalid records = regulatory violation. False rejection of valid records = customer harm. Both are equally unacceptable.
Rule 6: Fail Safe, Not Fail Silent	Every failure must return a meaningful, actionable validation code and description. Silent failures (TrackWizz accepts, CERSAI silently rejects) are the most dangerous failure mode.
Rule 7: A Rejected CKYC = Real Customer Harm	Behind every test record is a real bank customer who cannot open an account, get a loan, or make investments until their CKYC is registered. Test with this human consequence in mind.
Rule 8: Observability Is Not Optional	An API without monitoring is a black box. Production readiness requires real-time visibility into every submission, rejection, and performance metric.

Post-Production Considerations

Continuous Testing in Production

- Synthetic monitoring: Run a small set of test records through production API every hour to detect silent failures
- Canary testing on every deployment: 5% traffic → 25% → 100% with auto-rollback on error threshold breach
- Chaos engineering quarterly: scheduled chaos tests to validate resilience of production system
- Regulatory monitoring: Track RBI KYC amendment notifications — update test suite within 30 days of any change

Per-Bank Onboarding Testing

- Each new FI onboarding triggers a mini-UAT cycle using the FI's CBS data format
- Minimum 1,000 anonymized records from the FI tested before go-live
- Bank-specific integration test suite maintained per FI (documenting known quirks)
- Add 200-300 new test cases per bank for patterns not previously encountered
- FI-specific regression pack run on every API update before the FI is affected

Regulatory Change Management

- Maintain a regulatory change log: track all RBI/SEBI/IRDAI amendments affecting KYC
- CERSAI technical specification updates: monitor and test against new spec within 14 days
- New enum values (new state codes, new document types, new constitution types) — trigger field-level regression
- Periodic CERSAI reconciliation: compare TrackWizz accepted records vs CERSAI registered count monthly

Data Privacy & Compliance

- DPDP Act 2023: PAN and Aadhaar data handling must comply with data minimisation principles
- Test data management: all synthetic test data must be clearly marked and purged after test cycle
- Audit trail retention: verify 7-year retention for PMLA compliance annually
- Right to erasure vs KYC retention conflict: document and test resolution mechanism
- Annual security assessment: repeat Phase 11 (CERT-In audit) every 12 months

The Fundamental Truth About Production

No test suite, regardless of size or sophistication, can guarantee a complex financial API works perfectly with all production data across 12,000+ financial institutions serving 800 million customers. What this test strategy guarantees: • All documented business rules are correctly implemented • All known edge cases are handled gracefully • Security is independently certified to banking standards • The system fails safely and informatively — never silently • Recovery mechanisms work and are documented • Regulatory requirements are met as of the release date
The goal is not a perfect API. The goal is a resilient, observable, and recoverable API — one that can be trusted with the financial identity of every Indian bank customer.

